

Évaluation des risques : capteur d'ensoleillement LS-1, version 1.0

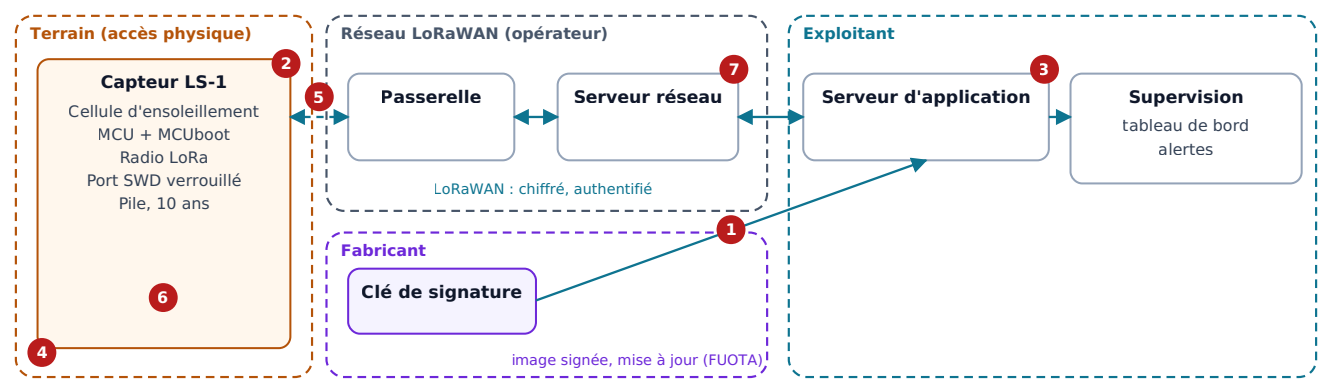
Exemple fictif, rédigé pour la série « CRA & Dev » afin d'illustrer l'article 13 du Cyber Resilience Act. Le produit, les choix et les cotations sont des exemples : ils ne remplacent pas l'analyse de votre propre produit.

1. Contexte

Rubrique	Contenu
Usage prévu	Mesurer l'éclairement solaire (W/m²) sur un site photovoltaïque ou agricole, et l'envoyer toutes les 15 minutes par LoRaWAN à la plateforme de l'exploitant, qui estime la production attendue.
Usage raisonnablement prévisible	Station météo d'une collectivité, données publiées en open data ; référence pour détecter une baisse de rendement des panneaux et déclencher une intervention.
Environnement	En extérieur, sur un mât, sur des sites clôturés ou non. Alimenté par pile. Réseau LoRaWAN public ou privé.
Actifs à protéger	Intégrité du firmware ; clés LoRaWAN (clé racine propre à chaque appareil) ; intégrité et disponibilité des mesures ; autonomie de la pile.
Données traitées	Éclairement, température interne, tension de la pile. Aucune donnée personnelle.
Durée d'utilisation prévue	10 ans. Période d'assistance : 10 ans.
Interfaces	Radio LoRaWAN (mesures, configuration, mises à jour) ; port de débogage SWD, verrouillé en production. Aucune interface locale pour l'utilisateur.

2. Schéma

Les numéros renvoient aux risques du tableau suivant.



3. Risques

Vraisemblance (V) et impact (I) : faible, moyen(ne), élevé(e).

#	Menace : qui, par où	V	I	Décision	Mesure ou justification
1	Un firmware malveillant est poussé par la mise à jour radio	faible	élevé	réduire	Image signée par le fabricant, vérifiée par MCUboot avant installation ; retour à une version antérieure interdit (point 2 c, f).

#	Menace : qui, par où	V	I	Décision	Mesure ou justification
2	La clé racine est extraite d'un capteur volé sur son mât	moyenne	faible	réduire	Clé unique par appareil : un vol ne compromet qu'un capteur. Port SWD verrouillé (point 2 d, j).
3	Une configuration abusive est envoyée (intervalle de 10 s qui vide la pile)	faible	moyen	réduire	Configuration acceptée seulement si elle est authentifiée par la session LoRaWAN ; valeurs bornées entre 5 min et 24 h (point 2 h).
4	La cellule est masquée ou réorientée sur place	moyenne	faible	accepter	Hors de portée de l'appareil. La plateforme compare les mesures aux capteurs voisins et à l'ensoleillement théorique.
5	La radio est brouillée, les mesures sont perdues	faible	faible	accepter	Perte de mesures sans conséquence de sécurité ; la plateforme signale un capteur silencieux.
6	Une vulnérabilité connue touche une dépendance (RTOS, pile LoRaWAN)	élevée	moyen	réduire	SBOM à chaque version, surveillance continue, correctif livré par mise à jour radio (partie II, points 1 et 2).
7	Après une panne, toute la flotte tente de rejoindre le réseau en même temps	moyenne	moyen	réduire	Tentatives espacées, avec un délai croissant et une part d'aléa (point 2 i).

4. Annexe I, partie I, point 2

Point	Applicable ?	Mise en œuvre, ou justification
a) Pas de vulnérabilité exploitable connue	Oui	Analyse du SBOM avant chaque version ; aucune vulnérabilité exploitable connue n'est livrée.
b) Sécurisé par défaut, retour à l'état d'origine	Oui	Aucun secret partagé par défaut ; intervalle de mesure prudent (15 min). Un bouton interne rétablit la configuration d'usine.
c) Mises à jour de sécurité	Oui	Mises à jour radio signées, installées automatiquement par défaut ; l'exploitant peut les différer.
d) Protection contre l'accès non autorisé	Oui	Pas d'interface locale ; SWD verrouillé ; seules les commandes authentifiées par la session LoRaWAN sont acceptées.
e) Confidentialité	Oui, enjeu faible	Charge utile chiffrée par LoRaWAN ; aucune donnée personnelle.
f) Intégrité	Oui	Trames authentifiées et compteurs de trames ; firmware signé ; configuration bornée.
g) Minimisation des données	Oui	Seules les trois grandeurs utiles sont transmises.
h) Disponibilité des fonctions essentielles	Oui	Chien de garde ; la mesure ne dépend pas de la réception de commandes ; configuration bornée.
i) Pas d'impact sur les autres réseaux	Oui	Respect du rapport cyclique radio ; tentatives de connexion espacées.
j) Surface d'attaque limitée	Oui	Une seule interface externe, la radio ; SWD verrouillé.
k) Limitation de l'exploitation	Oui	Durcissement du compilateur et du RTOS (canaris de pile, protection mémoire MPU).
l) Journalisation et surveillance	Oui, sous forme réduite	Redémarrages, échecs de connexion et résultats de mise à jour comptés et envoyés dans un message d'état quotidien, désactivable par configuration.

Point	Applicable ?	Mise en œuvre, ou justification
m) Effacement des données et réglages	Oui	Le retour usine efface la session, la configuration et les mesures en attente. La clé racine est conservée : c'est l'identité de l'appareil, pas une donnée de l'utilisateur.

5. Annexe I, partie I, point 1, et partie II

- **Niveau de cybersécurité visé : modéré.** Le capteur ne traite aucune donnée personnelle et ne commande rien ; une mesure fausse ou perdue n'a qu'un impact d'exploitation.
- **Gestion des vulnérabilités :** SBOM CycloneDX à chaque version, surveillance continue des dépendances, adresse de contact publiée avec une politique de divulgation, correctifs livrés par mise à jour radio, avis de sécurité publiés.

6. Historique

Date	Version	Changement
2026-10-06	1.0	Première évaluation.